KOPDES MERAH PUTIH

Buku Panduan Teknis & Dokumentasi Resmi Backend REST API

Panduan integrasi lengkap untuk Divisi Front-End, Mobile Developer, dan Administrator Sistem Koperasi Desa. Mencakup alur Pendaftaran Anggota, Pembayaran QRIS (Normal & Auto-Lock), Maker-Checker, Iuran Bulanan, dan Deployment VPS.

Penyusun: Tim Arsitektur & Keamanan Sistem Kopdes Merah Putih

Teknologi: Golang (Go 1.24), PostgreSQL 16 (Multi-Tenant RLS & Partitioning)

Standar Regulasi: PADG BI 21/18/PADG/2019 (QRIS) & UU No. 27 Tahun 2022 (PDP)

Status Dokumen: Versi 1.2 — Siap Produksi & Uji Coba Lapangan (Pilot Test)

Tanggal Pembaruan: 9 November 2026

1. Pengenalan & Pondasi Arsitektur Sistem

Kopdes Merah Putih adalah platform perbankan desa dan koperasi konsumen terdistribusi yang dirancang dengan standar keamanan tingkat tinggi (fintech-grade). Sistem backend dibangun menggunakan bahasa **Golang** dengan mesin basis data **PostgreSQL 16**.

> **5 Pilar Keamanan & Integritas Data Utama:**
>
> 1. **Isolasi Multi-Tenant & RLS:** Setiap query bisnis otomatis disaring oleh PostgreSQL `FORCE ROW LEVEL SECURITY` melalui session variable `app.current_koperasi_id` yang diekstrak murni dari token JWT (Mencegah kerentanan OWASP API1:2023 BOLA).
> 2. **Maker-Checker Guard:** Pembuat transaksi/pembayaran dilarang memverifikasi pembayarannya sendiri (Pencegahan fraud internal pengurus).
> 3. **Anti-Float Financial:** Seluruh perhitungan nilai uang menggunakan tipe data SQL `NUMERIC(18,2)` dan `int64` di Go untuk mencegah selisih pembulatan sen.
> 4. **Append-Only Audit Journal:** Tabel mutasi kas, log verifikasi, dan status dilarang keras di- `UPDATE` atau di- `DELETE` . Koreksi saldo wajib melalui entri reversal akuntansi.
> 5. **Enkripsi Data Pribadi:** NIK, Tanggal Lahir, dan Nomor HP dienkripsi menggunakan AES-256-GCM dengan Blind Index HKDF-SHA256 untuk fitur pencarian cepat tanpa membuka plaintext (rancangan proteksi PII, memerlukan audit hukum formal).

2. Fleksibilitas Konfigurasi Port & Lingkungan (.env)

Seluruh port server API maupun basis data dapat diubah secara bebas melalui file `.env` tanpa perlu melakukan kompilasi ulang pada kode program.

Variabel .env	Nilai Default	Fungsi & Penjelasan
`API_PORT` / `API_HOST_PORT`	`Dikonfigurasi di .env`	Port HTTP Server API & port publik host Docker (misal Set A vs Set B `18080`, dikonfigurasi via `.env`).
`DB_PORT`	`5433` (dev) / `5432` (vps)	Port PostgreSQL. Jika menggunakan docker-compose di VPS, gunakan 5432.
`DATABASE_URL`	`postgres://...`	DSN lengkap koneksi database. Otomatis menyerap variabel host, user, dan port.
`JWT_SECRET`	*32-byte Hex*	Kunci rahasia penandatanganan token otentikasi login pengguna.
`ALLOWED_ORIGINS`	`http://localhost:3000`	Daftar domain Front-End web yang diizinkan melakukan request lintas-domain (CORS).

Cara Menjalankan Backend:

A. Mode Pengembangan Lokal (Windows / Linux):

```
# 1. Pastikan PostgreSQL 16 menyala
# 2. Jalankan server API
go run ./cmd/server
# Server aktif pada port yang diset di API_PORT (misal http://0.0.0.0:${API_PORT})
```

B. Mode Server / VPS Produksi (Docker Compose):

```
# Kloning repo, salin konfigurasi, dan nyalakan dalam 1 perintah
cp .env.example .env
docker compose up -d --build
```

3. Panduan Fitur Pembayaran QRIS: Dua Model Pilihan

Kopdes Merah Putih menyediakan dua model adopsi QRIS untuk menjembatani kebutuhan antara tahap awal desa yang praktis tanpa izin rumit, hingga tahap modern koperasi skala besar.

MODEL 1 (Pilihan Saat Ini: QRIS Normal / Perorangan + Kode Unik Manual)

Mengapa Memakai Cara Ini? Anda tidak perlu menunggu pengurusan Akta Notaris Kemenkumham atau verifikasi rekening badan hukum bank yang memakan waktu berbulan-bulan. Anda bisa langsung memulai uji coba hari ini!

1. **Pendaftaran:** Pengurus mendaftarkan QRIS perorangan milik bendahara/ketua (misal dari GoPay Merchant Mikro, Dana Bisnis, Livin Mandiri, atau BCA) via menu Admin.
2. **Pembuatan Tagihan:** Anggota membuat tagihan (misal Iuran Rp 20.000). Sistem otomatis mengalokasikan 3-digit kode unik (misal 142) sehingga total transfer menjadi **Rp 20.142**.
3. **Pembayaran:** Anggota memindai stiker fisik QRIS bendahara di kantor desa lewat m-banking apa saja (BCA, Livin, BRImo, Dana), lalu mengetikkan nominal pas **Rp 20.142**.
4. **Verifikasi:** Bendahara melihat mutasi masuk Rp 20.142 di aplikasi HP miliknya, lalu mengklik tombol "*Verifikasi Pembayaran*" di sistem Kopdes.

MODEL 2 (Pilihan Otomatis: Dynamic QRIS Auto-Lock Nominal)

Bagaimana Cara Kerjanya? Algoritma backend di `internal/qris/emvco.go` secara otomatis mengubah payload QRIS menjadi QRIS Dinamis berstandar Bank Indonesia (PADG BI 21/18/PADG/2019):

- Tag `01` diubah menjadi `'12'` (Dynamic Point of Initiation).
- Tag `54` disuntikkan dengan total nominal pas (misal `20142`).
- Tag `62` disuntikkan dengan nomor invoice unik (misal `PAY-886f-0300`).
- Tag `63` dihitung ulang checksum CRC16-CCITT False.

Hasilnya: Saat kode QR di layar HP atau web di-scan oleh anggota, **layar nominal di aplikasi bank otomatis terkunci** pada angka Rp 20.142. Anggota tidak bisa salah ketik nominal!

4. Modul Pendaftaran Anggota & Perlindungan Data Pribadi (UU PDP)

Sesuai mandat **Undang-Undang No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP)**, sistem Kopdes Merah Putih menerapkan enkripsi dua lapis untuk seluruh data identitas warga desa:

Data Sensitif	Metode Penyimpanan	Tujuan & Implementasi
NIK (Nomor Induk Kependudukan)	`nik_enkripsi` (AES-256-GCM) `nik_hash` (HMAC-SHA256)	Plaintext NIK tidak pernah tersimpan di database. Kolom hash berfungsi sebagai Blind Index agar pencarian tetap instan via indeks B-Tree tanpa perlu mendekripsi seluruh baris data.
Nomor Handphone	`no_hp_enkripsi` (AES-256-GCM) `no_hp_hash` (HMAC-SHA256)	Melindungi nomor pribadi anggota dari kebocoran SMS/spam pemasaran ilegal.
Alamat & Tanggal Lahir	`alamat_enkripsi`, `tanggal_lahir_enkripsi`	Dienkripsi penuh menggunakan AES-256-GCM dengan nonce acak per record.

5. Referensi Lengkap Endpoint API Backend

Semua respons API menggunakan amplop standar JSON: `{"success": true, "data": {...}}`.

POST **/api/v1/auth/login** Publik

Otentikasi pengguna menggunakan email dan password untuk mendapatkan Access Token JWT.

Request Body:

```
{
  "email": "budi@kopdes.id",
  "password": "PasswordKuat123!"
}
```

Response Sukses (200 OK):

```
{
  "success": true,
  "data": {
    "access_token": "",
    "token_type": "Bearer",
    "expires_in_seconds": 86400,
    "user": {
      "id": "0193108c-9a4f-7cd3-...",
      "nama_lengkap": "Budi Utomo",
      "email": "budi@kopdes.id",
      "koperasi_id": "0193108c-8f12-7000-...",
      "roles": ["anggota"]
    }
  }
}
```

POST `/api/v1/pembayaran/qris` — Bearer Token (Semua Role)

Mengalokasikan pembayaran QRIS dengan 3-digit kode unik anti-tabrakan dan generator Auto-Lock Nominal.

Request Body:

```
{
  "nominal_dasar": 50000,
  "jenis_transaksi": "iuran_bulanan",
  "anggota_id": "0193108c-bf53-7000-..."
}
```

Response Sukses (201 Created):

```
{
  "success": true,
  "data": {
    "pembayaran_id": "0193109a-4c12-7011-...",
    "no_pembayaran": "PAY-886f888a-0300",
    "kode_unik": 112,
    "nominal_dasar": 50000,
    "nominal_total": 50112,
    "qris_payload": "0002010102122666...5405501125802ID5913KOPDES MAKMUR6007BANDUNG62210117PAY-88
    "is_autolock_nominal": true,
    "nama_merchant": "KOPDES MAKMUR",
    "nmid": "ID1020304050607",
    "berlaku_sampai": "2026-11-09T16:00:00Z",
    "sisa_waktu_detik": 3600
  }
}
```

GET /api/v1/pembayaran/{id}

Bearer Token

Memeriksa status terkini transaksi pembayaran (Polling front-end untuk mendeteksi konfirmasi pelunasan).

Response Sukses (200 OK):

```
{
  "success": true,
  "data": {
    "id": "0193109a-4c12-7011-...",
    "status": "menunggu_pembayaran",
    "no_pembayaran": "PAY-886f888a-0300",
    "nominal_total": "50112.00",
    "berlaku_sampai": "2026-11-09T16:00:00Z",
    "referensi_rrn": null
  }
}
```

POST /api/v1/koperasi/rekening-qris

Role: Admin / Pengurus

Mendaftarkan stiker / data QRIS milik koperasi (baik QRIS perorangan sementara maupun QRIS merchant resmi).

Request Body:

```
{
  "nama_merchant": "KOPDES MERAH PUTIH MANDIRI",
  "nmid": "ID1020304050607",
  "nama_bank_pjp": "Bank Mandiri",
  "no_rekening_settlement": "1300099887766",
  "nama_pemilik_rekening": "Koperasi Merah Putih Mandiri",
  "is_atas_nama_badan_hukum": true,
  "qris_payload_statis": "0002010102112666...6304ABCD"
}
```

Response Sukses (201 Created):

```
{
  "success": true,
  "data": {
    "id": "019310ba-1100-7fa3-...",
    "nama_merchant": "KOPDES MERAH PUTIH MANDIRI",
    "nmid": "ID1020304050607",
    "status_aktif": true,
    "pesan": "Rekening QRIS statis badan hukum koperasi berhasil didaftarkan."
  }
}
```

POST `/api/v1/pembayaran/{id}/verifikasi` — Role: Admin / Pengurus / Operator

Menyetujui atau menolak bukti pembayaran anggota. **Maker-Checker: Ditolak otomatis (HTTP 403) jika pembuat pembayaran mencoba memverifikasi transaksinya sendiri.**

Request Body:

```
{
  "disetujui": true,
  "referensi_rrn": "123456789012",
  "nominal_aktual": 50112,
  "catatan": "Uang masuk di mutasi Bank Mandiri pukul 14:15"
}
```

Response Sukses (200 OK):

```
{
  "success": true,
  "data": {
    "pembayaran_id": "0193109a-4c12-7011-...",
    "status": "berhasil_diverifikasi",
    "pesan": "Verifikasi pembayaran berhasil dicatat ke jurnal append-only."
  }
}
```

POST `/api/v1/iuran/generate` — Role: Admin / Pengurus

Menjalankan proses pembuatan tagihan iuran bulanan untuk seluruh anggota aktif secara idempoten.

Request Body:

```
{
  "jenis_iuran_id": "0193108d-5122-7bc1-...",
  "periode": "2026-11"
}
```

GET `/api/v1/iuran/menunggak?min_bulan=2` — Role: Admin / Pengurus

Mengambil daftar anggota yang menunggak pembayaran iuran lebih dari N bulan untuk keperluan peringatan pengurus desa.

GET `/api/v1/katalog/stok` — Semua User

Menampilkan stok saldo gudang dan sisa kuota barang bebas jual di toko koperasi desa.

GET `/api/v1/katalog/harga?produk_id={id}&anggota_id={id}` — Semua User

Menghitung harga barang secara dinamis dengan memperhitungkan tier diskon khusus anggota koperasi.

POST `/api/v1/pendaftaran` — Calon Anggota

Mengajukan formulir pendaftaran anggota baru. Data sensitif (NIK, Tanggal Lahir, Alamat) otomatis dienkripsi dengan AES-256-GCM + AAD, nomor registrasi dibuat secara atomik (REG/YYYY/XXXXX), dan duplikasi NIK dicegah via Blind Index HKDF-SHA256.

Request Body:

```
{
  "nik": "3201123456780001",
  "nama_lengkap": "Budi Santoso",
  "tempat_lahir": "Bogor",
  "tanggal_lahir": "1990-05-15",
  "jenis_kelamin": "L",
  "alamat_ktp": "Jl. Raya Desa No. 10",
  "pekerjaan": "Petani"
}
```

Response Sukses (201 Created):

```
{
  "success": true,
  "data": {
    "pendaftaran_id": "0193109b-1234-7000-...",
    "no_registrasi": "REG/2026/00001",
    "status": "diajukan"
  }
}
```

GET `/api/v1/pendaftaran/{id}` — Pemohon / Admin

Memeriksa status pendaftaran calon anggota. Dilindungi anti-IDOR (pemohon lain mendapat 404). NIK ditampilkan dalam bentuk tersamar (masking) otomatis `3201********0001`.

POST `/api/v1/pendaftaran/{id}/dokumen` — Pemohon (Multipart)

Mengunggah foto KTP / dokumen KYC calon anggota. Sistem memvalidasi Magic Bytes file asli (hanya menerima JPEG, PNG, PDF asli), menolak script/eksekutabel, membatasi ukuran maksimal 5MB, dan mencatat checksum integritas SHA-256.

POST `/api/v1/pendaftaran/{id}/verifikasi` — Role: Admin / Pengurus (Maker-Checker)

Memproses verifikasi penerimaan calon anggota. Dilindungi kontrol Maker-Checker (pemohon dilarang menyetujui pendaftarannya sendiri). Saat disetujui, nomor anggota unik `ANG/2026/XXXXX` diterbitkan secara atomik dan akun pengguna langsung dipromosikan ke role `anggota`.

Request Body:

```
{
  "status": "disetujui",
  "catatan_perbaikan": "Dokumen KTP valid dan terverifikasi"
}
```

POST `/api/v1/pendaftaran/purge-ditolak` — Role: Admin / Pengurus (UU PDP)

Menjalankan prosedur pembersihan berkas fisik dan enkripsi PII bagi formulir pendaftaran yang ditolak lebih dari masa retensi terkonfigurasi (default 30 hari; catatan: perlu verifikasi hukum formal).

GET `/api/v1/kas/mutasi` — Role: Admin / Pengawas

Membaca catatan buku mutasi kas masuk/keluar terpartisi bulanan berantai hash SHA-256 append-only (dilindungi trigger anti-TRUNCATE).

GET `/metrics` — Bearer METRICS_TOKEN (>= 32 byte)

Eksposisi metrik operasional Prometheus (uptime, antrean verifikasi pembayaran, slot kode unik QRIS aktif, total job gagal, dan status partisi database). Wajib menyertakan `Authorization: Bearer <METRICS_TOKEN>`; akses tanpa token ditolak `401`.

6. Panduan Praktis Integrasi Front-End (Web & Mobile)

Divisi Front-End memiliki kebebasan penuh dalam merancang antarmuka UI/UX. Berikut adalah modul siap pakai untuk menghubungkan aplikasi ke backend Go.

A. Modul Klien API (TypeScript / Fetch)

```
// lib/apiClient.ts
const BASE_URL = process.env.NEXT_PUBLIC_API_URL ?? "";
if (!BASE_URL) {
  throw new Error("NEXT_PUBLIC_API_URL wajib diisi di .env.local");
}

export async function kopdesAPI<T>(endpoint: string, options: RequestInit = {}): Promise<T> {
  const token = typeof window !== "undefined" ? localStorage.getItem("kopdes_token") : null;
  const headers = new Headers(options.headers || {});
  headers.set("Content-Type", "application/json");
  if (token) {
    headers.set("Authorization", `Bearer ${token}`);
  }

  const res = await fetch(`${BASE_URL}${endpoint}`, { ...options, headers });
  const json = await res.json();

  if (!res.ok || !json.success) {
    throw new Error(json.error?.message || "Terjadi kesalahan pada server");
  }
  return json.data;
}
```

B. Komponen Pembayaran QRIS (React / Next.js)

```
import React, { useState, useEffect } from "react";
import QRCode from "qrcode.react"; // npm install qrcode.react
import { kopdesAPI } from "../lib/apiClient";

export function PembayaranQRIS({ tagihanIds }: { tagihanIds: string[] }) {
  const [data, setData] = useState<any>(null);
  const [lunas, setLunas] = useState(false);

  useEffect(() => {
    // 1. Buat alokasi QRIS dengan Idempotency-Key
    kopdesAPI("/api/v1/pembayaran/qris", {
      method: "POST",
      headers: { "Idempotency-Key": crypto.randomUUID() },
      body: JSON.stringify({ jenis_transaksi: "iuran_bulanan", tagihan_iuran_id: tagihanIds })
    }).then(res => setData(res));
  }, [tagihanIds]);

  // 2. Polling status pelunasan setiap 10 detik
  useEffect(() => {
    if (!data || lunas) return;
    const interval = setInterval(async () => {
      try {
        const res: any = await kopdesAPI(`/api/v1/pembayaran/${data.pembayaran_id}`);
        if (res.status === "disetujui") {
          setLunas(true);
          clearInterval(interval);
        }
      } catch (_) {}
    }, 10000);
    return () => clearInterval(interval);
  }, [data, lunas]);

  if (!data) return <p>Memuat QRIS...</p>;
  if (lunas) return <h2 style={{color: "green"}}>Pembayaran Berhasil Dikonfirmasi!</h2>;

  return (
    <div style={{ textAlign: "center", padding: "20px", border: "1px solid #ddd", borderRadius: "12px
      <h3>{data.nama_merchant}</h3>
      <QRCode value={data.qris_payload} size={240} level="M" />
      <h1 style={{ color: "#dc2626" }}>Rp {data.nominal_total.toLocaleString("id-ID")}</h1>
      <p>Kode Unik Transaksi: <b>{data.kode_unik}</b></p>
      <small style={{ color: "#666" }}>Nominal otomatis terkunci saat discan via m-banking</small>
    </div>
  );
}
```

Frontend Tester Polos & Kontrak Lengkap (54 Operasi / 48 Path): Gunakan `cmd/uitester` (`UI_PORT` & `API_PUBLIC_URL` dari `.env.test`) bersama `frontend-tester/` untuk menguji OpenAPI Explorer, alur terpandu 3.1–3.9, 26 skenario `scenarios.json` , serta matriks RBAC `roles_matrix.json` langsung di browser tanpa framework maupun penyimpanan token persisten. Konfigurasi total berjumlah 83 variabel di `docs/ENV_REFERENCE.md` .

7. Pertanyaan Umum & Troubleshooting (FAQ)

T: Mengapa login saya mendapatkan error 401 saat user baru dibuat?
J: Pastikan password yang dikirimkan cocok dengan password saat seeding, dan pastikan user tersebut telah dikaitkan dengan role di tabel `user_roles` untuk koperasi yang bersangkutan.

T: Apakah anggota wajib transfer menggunakan nominal pas beserta kode unik?
J: Ya, wajib. Jika anggota mentransfer tanpa kode unik (misal pas Rp 20.000 bukan Rp 20.142), sistem akan mendeteksi selisih bayar (`selisih_bayar <> 0`) dan admin harus melakukan penyesuaian manual di antrean verifikasi.

T: Bagaimana jika server PostgreSQL dipindahkan ke server lain?
J: Anda cukup mengedit file `.env` pada variabel `DB_HOST` , `DB_PORT` , `DB_USER` , dan `DB_PASSWORD` . Backend Go otomatis membaca konfigurasi baru tanpa kompilasi ulang.